

Inside the Ear Canal

A Chained Vulnerability Disclosure for a Consumer Ear-Canal Camera

Matthew Dubbrin

Vexel Foundation

Coordinated through CISA (advisory pending publication) · CVE-2026-81330, CVE-2026-81640, CVE-2026-82563, CVE-2026-77974

Abstract—The Softish C6 is a consumer ear-canal camera, sold under multiple white-label brand names and controlled by an Android application, EarVision, over a device-hosted Wi-Fi access point. I present four vulnerabilities discovered through static analysis of the companion application and passive wireless capture of the device's control and video protocol: cleartext transmission of live video, an access-point credential algorithmically derivable from a value broadcast in every beacon frame, acceptance of an unauthenticated rogue access point as the genuine device, and an unauthenticated, unsigned over-the-air firmware update path. Individually, each is a familiar class of IoT defect. Composed, they form a single passive-to-active chain: an attacker who only reads beacon frames can recover the Wi-Fi credential, decrypt the video feed, impersonate the device to the application, and, with one user tap, deliver an arbitrary firmware image with no signature check. I argue this chain is materially worse than the median IoT camera disclosure because the data in transit is medical-adjacent, frequently depicts a minor, and because no accountable vendor security contact could be established for the product. All four issues were coordinated through CISA; its advisory was pending publication as of this writing. Consistent with my exploit-code policy (Section IX), I withhold the credential derivation routine, rogue-access-point implementation, and video reconstruction tooling.

Index Terms—IoT security, medical device privacy, cleartext transmission, derivable credentials, authentication bypass, unsigned firmware, coordinated disclosure

I. INTRODUCTION

Most consumer IoT camera disclosures end with the observation that an attacker can watch a living room. This one ends with an attacker watching inside a body cavity, on hardware marketed for use on children, secured by a password that is broadcast in the clear ten times a second.

The Softish C6 is a handheld otoscope: a camera at the tip of a probe, a Wi-Fi radio in the handle, and no cloud service in between. A companion Android application, EarVision (package `com.atomath.wifi_camera`), streams the feed live to the user's phone. The same reference hardware ships under several storefront names, a typical arrangement for white-label IoT, which is itself a contributing factor in the disclosure difficulty documented in Section VII.

I treat this device as a case study rather than a set of isolated findings because the four vulnerabilities identified do not fail independently. Each removes one control from the same trust boundary—transport, credential, identity, and integrity, in that order—and each failure makes the next easier to reach. Section V formalizes this as a single attack graph. The practical result is that an attacker's cost to go from being in radio range to having pushed unsigned firmware to the device is a passive capture, an inexpensive

microcontroller, and one tap on a prompt that the legitimate update flow also produces.

What distinguishes this device from a generic security-camera advisory is the sensitivity of the data in transit. The footage is ear-canal anatomy, eardrum condition, and any hearing-assistive hardware the subject wears; the product is marketed to parents as a way to check a child's ear at home rather than book a clinician visit. I return to this point in Section X, but it motivates the severity framing used throughout this paper: confidentiality of the video channel is treated as the anchor harm, not an afterthought to the firmware-integrity finding.

II. SYSTEM ARCHITECTURE AND THREAT MODEL

The C6 does not join the user's home network. It is its own access point: the phone disconnects from whatever network it was previously on, associates to the camera's SSID (of the form `softish-XXXXXX`, where the suffix is derived from the device's BSSID), and the app speaks to the device directly over two UDP ports. There is no broker, no cloud relay, and, outside of the firmware images bundled in the APK itself, no external infrastructure involved in normal operation.

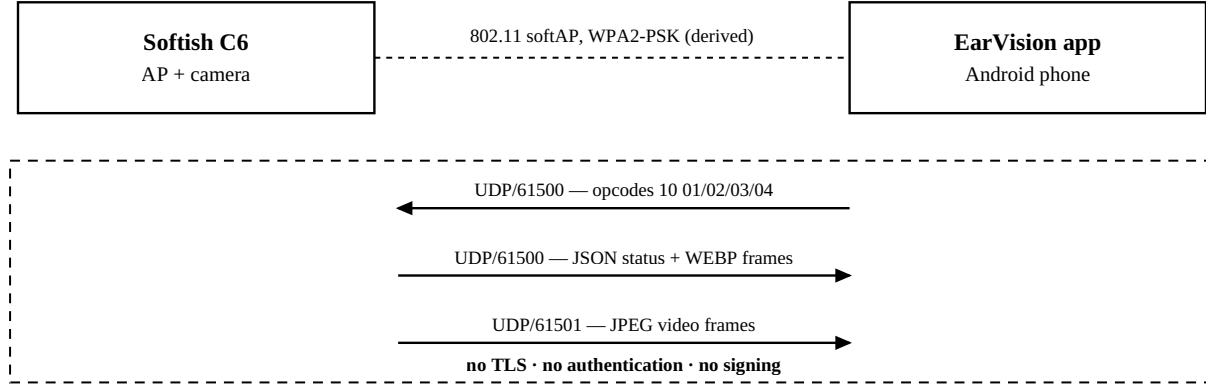


Fig. 1. Protocol overview. Port 61500 is bidirectional—control opcodes travel phone to device, JSON status and WEBP-encoded frames travel device to phone on the same port—while port 61501 carries a separate JPEG stream device to phone. No channel is encrypted, authenticated, or integrity-checked.

The application manifest declares this posture explicitly: `android:usesCleartextTraffic="true"`. There is no TLS configuration to audit for weakness, because there is no TLS. The threat model evaluated here is accordingly the

simplest possible one for a wireless device: an attacker with a commodity Wi-Fi adapter in monitor mode, within radio range of either the camera or the phone, with no prior credential and no physical access to either device.

Table I
CONFIRMED CONTROL OPCODES, UDP/61500 (PHONE → DEVICE)

Opcode	Length	Function
10 01	2 B	Metadata poll; device responds with JSON status
10 02	2 B	Stream start request
10 03	4 B	Periodic metadata poll
10 04	786 B	OTA initiation; 16-byte header plus raw firmware image (Section IV-D)

III. METHODOLOGY

All testing was performed against researcher-owned hardware in a researcher-controlled environment. No third-party device, network, or user was involved at any point.

- *Static analysis.* The EarVision APK was decompiled and its manifest, bundled assets, and Java/Flutter platform bridge reviewed. This is where the cleartext-traffic flag, the three bundled firmware images, the MNN inference plugin, and a bundled TFLite model disguised with a non-standard extension were located.
- *Wireless capture.* A wireless interface was placed in monitor mode and traffic between phone and camera captured across normal app usage: pairing, live viewing, still capture, and update checks.
- *Protocol analysis.* The two UDP channels were separated, the control opcodes on port 61500 enumerated (Table I), and the JSON status schema mapped field by field.

- *Frame reconstruction.* JPEG and WEBP frames were rebuilt from captured UDP payloads to confirm the video is fully recoverable from a passive capture alone.
- *Spoofing proof of concept.* A rogue access point replicating the device's observed BLE and Wi-Fi identity was used to confirm the app accepts it as genuine, and that attacker-supplied version fields in the status JSON reliably produce the OTA prompt and subsequent firmware transfer.

IV. FINDINGS

Four CVEs were assigned, coordinated through CISA [1]. They are presented in the order used to brief the coordinating body: the passively observable privacy failure first, then the two findings that compose into a full man-in-the-middle position, then the finding that turns that position into arbitrary code execution.

Table II
SUMMARY OF ASSIGNED CVEs

CVE	Finding	CWE	CVSS 3.1
2026-81330	Cleartext live video over UDP	319	6.5 (Medium)
2026-81640	AP password derivable from broadcast BSSID	798	8.8 (High)
2026-82563	Device identity accepted from broadcast values	290	7.6 (High)
2026-77974	Unauthenticated, unsigned OTA firmware transfer	306	8.0 (High)

None of the four reach the Critical band (9.0 and above) under standard CVSS v3.1 thresholds. CVE-2026-81640, the password-derivation issue, is the highest-scoring of the four despite reading as the quieter, enabling step in the narrative below.

A. Cleartext Video Over UDP (CVE-2026-81330)

Video leaves the device as ordinary JPEG frames on UDP/61501 (an 8-byte transport header followed by SOI/EOI-delimited JPEG data) and as WEBP frames interleaved with JSON control traffic on UDP/61500. Neither channel carries transport or application-layer encryption. Possession of the AP password, which per Section IV-B requires no cracking, is the only thing separating an observer from the video.

Frame reconstruction quality in testing tracked capture quality directly: packet loss surfaced as dropped frames rather than failure. The attack degrades gracefully, the wrong property for a confidentiality control to have. Recovery is entirely passive; neither the camera nor the app can detect it, and the user has no indication it is occurring.

B. Wi-Fi Password Derivable From a Public Value (CVE-2026-81640)

The C6's access-point password is unique per device rather than a single value shared across the product line, an implementation choice that on its face looks correct. It is undermined by how that per-device value is produced: it is algorithmically derivable from the device's BSSID, which every C6 broadcasts in the clear, in every beacon frame, several times a second, to anyone listening. A value designed to be public cannot also function as the seed for a secret.

This sits between two weakness categories rather than squarely in one: the credential is not literally hardcoded in firmware (CWE-798 is nonetheless the officially assigned

weakness here), but it is fully and deterministically derived from a broadcast value, producing the same practical outcome by way of insufficient entropy in the derivation. An attacker in range reads the BSSID off the air and computes the key with no handshake capture, no dictionary, and no cracking time required. Consistent with Section IX, the derivation function itself is withheld.

C. Device Identity Accepted Without Cryptographic Proof (CVE-2026-82563)

EarVision decides whether an endpoint is a genuine C6 using only broadcast identifiers, the Wi-Fi SSID and a BLE advertisement identity, rather than any cryptographic proof of possession. There is no device certificate, challenge-response, shared secret proved over the channel, or signature on device responses. An inexpensive microcontroller that replicates the expected BLE advertisement while hosting a matching SSID is accepted by the app as the real device, including auto-join, because the phone already holds the AP credential from a prior legitimate connection and Section IV-B makes that credential trivial to reproduce independently as well.

Once accepted, the rogue endpoint controls every field of every JSON status response and every byte of every UDP/61500 reply, a full man-in-the-middle position requiring no further work. This is the pivot into Section IV-D.

D. Unauthenticated, Unsigned Firmware Update (CVE-2026-77974)

The C6 inverts the usual IoT firmware model: images are not fetched by the device from a vendor server, they are bundled inside the Android APK and pushed to the camera by the phone. Three images ship in the app, one per chipset variant (Table III).

Table III
BUNDLED FIRMWARE IMAGES (EXTRACTED FROM EARVISION v1.3.1)

File	Size	Chipset
bk7252n_251117.bin	616 KB	Beken BK7252N
txw806_111.bin	368 KB	TXW806
txw810_125.bin	321 KB	TXW810

The update decision is driven entirely by two device-reported fields in the status JSON: if `ota_device_version` is reported greater than `device_version`, EarVision presents an update prompt. Neither field is authenticated, and both

arrive over an unencrypted channel from an endpoint the app never cryptographically verified (Section IV-C). When the user accepts, the app transmits the bundled image over UDP/61500 as opcode `10 04` (Table IV).

Table IV
CONFIRMED 10 04 OTA PACKET LAYOUT

Offset	Length	Field
0x00	2 B	OTA opcode (<code>10 04</code>)
0x02	4 B	Current device version, little-endian
0x06	4 B	Firmware size in bytes
0x0A	2 B	Padding
0x0C	4 B	Partition / chip identifier
0x10	770 B	Raw firmware image, byte 0 onward

I confirmed the transmitted payload is byte-for-byte identical to the bundled asset, not merely similar, by comparing the packet body against the extracted firmware file directly at every offset. No authentication guards the status channel that triggers the prompt (CWE-306, the officially assigned weakness for this CVE); no signature binds the image to the vendor; and the firmware header itself confirms integrity checking is disabled at the source, with both its CRC-32 and CRC-16 fields zeroed. The device acknowledged the transfer in its status response; confirming persistence across a power cycle would additionally require a physical flash dump, which was out of scope for this disclosure. The user-facing accept

prompt is the only remaining gate, and it is visually identical to the prompt a legitimate update produces—the user cannot distinguish them because the app cannot.

V. THE COMPOSITE ATTACK CHAIN

Individually, each finding above is a common IoT defect with numerous public precedents (Section VI). Composed, they form one continuous escalation from a completely passive starting point to arbitrary code execution on the device, requiring exactly one moment of victim interaction at the final step.

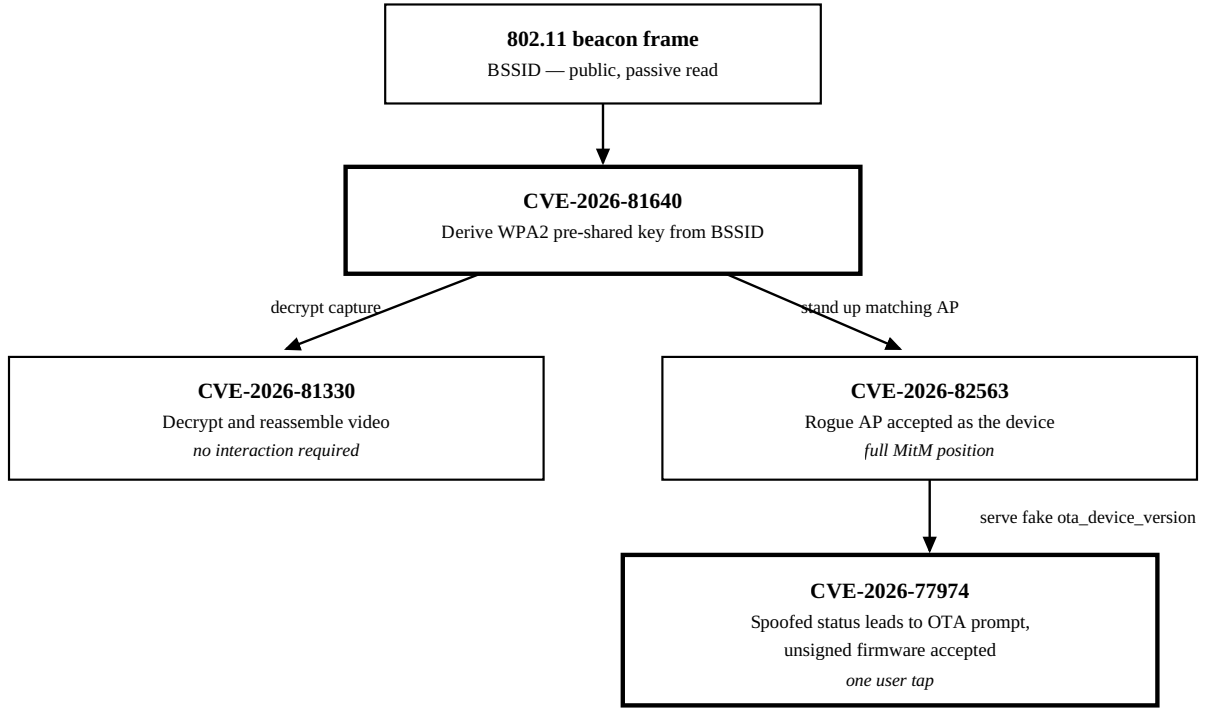


Fig. 2. The four findings as a single attack graph. The left branch (video interception) needs no user interaction at any point; the right branch (identity spoofing) converges on firmware push, which needs exactly one tap on a prompt visually indistinguishable from a legitimate update.

Two properties of this chain are worth stating plainly. First, the step with the largest technical consequence, arbitrary firmware execution, requires the least technical sophistication of any step, because Sections IV-B and IV-C do all the work of positioning the attacker; the final step is a JSON field and a UDP send. This is a different measure than the CVSS ranking in Table II: CVE-2026-81640 scores highest because it needs no user interaction and no prior access whatsoever, while CVE-2026-77974 is what actually hands the attacker persistent code execution. Second, the video-interception branch (Section IV-A) needs no chain at all: it is independently exploitable by anyone who captures the AP

handshake or derives the password, with zero interaction with the app or its user.

VI. RELATED WORK

None of the four failure classes here are novel. Each has a well-known, independently disclosed precedent, several in categories more consequential than a novelty camera, which is precisely the point: this is not a research problem, it is a pattern that recurs because nothing in the supply chain is accountable for fixing it (Section X).

Table V
COMPARABLE DISCLOSED INCIDENTS BY FAILURE CLASS

Incident	Failure class	Parallel
Mirai botnet, 2016 [2]	Hardcoded/derivable factory credentials on cheap DVRs and IP cameras	IV-B
Arlo cameras [3]	Predictable post-setup Wi-Fi credential	IV-B
TP-Link Archer NX, CVE-2025-15517 [4]	Missing auth check permitting unauthorized firmware upload	IV-D
Wyze Cam, CVE-2019-9564 [5]	Auth-bypass camera takeover via spoofable device identity	IV-C
Hospira infusion pumps, CISA ICSA-15-125-01 [6]	Unauthenticated, unsigned firmware on a medical device	IV-D
St. Jude/Abbott cardiac devices, FDA recall 2017 [7]	Weak/spoofable RF authentication on an implanted device	IV-C

The Hospira and St. Jude/Abbott cases are the closest analogs in consequence class rather than device class: both are medical devices where a missing authentication or integrity control on a reachable update path became a patient-safety issue rather than a privacy one. The C6 is not an infusion pump or a pacemaker, but it is marketed into the same device-touches-a-body, consumer-cost-target category, with none of the design scrutiny those categories eventually received after regulatory intervention.

VII. DISCLOSURE AND VENDOR RESPONSE

Initial discovery took place in May 2026 during static analysis of the EarVision APK. The findings were coordinated through CISA; CVE-2026-81330, -81640, -82563, and -77974 were published on 2 September 2026. CISA's advisory for this coordination was still pending publication as of this writing.

I attempted to identify a vendor security contact before proceeding through CISA. The manufacturer of record, Shenzhen Jiding Electronics Co., Ltd., could be identified from the app's bundled privacy policy, but that document lists only a generic, personal-provider email address for privacy-policy questions, not a security contact, not tied to a published disclosure process, and not confidence-inspiring as a channel for a report of this severity. No `security.txt`, dedicated vulnerability-disclosure page, or security address appears on any storefront or documentation associated with the product or its white-label variants. This is the ordinary condition for this class of hardware, and it is the reason coordination proceeded through CISA rather than direct vendor contact.

VIII. RECOMMENDATIONS

A. For Owners of This Device

There is no patch to apply. Treat any footage the device captures as though it were broadcast publicly, because in effect it is; power the device on only for the duration of an actual use, since the access point is live for as long as the device is on; do not use it anywhere a stranger in range watching the feed would be unacceptable; decline firmware update prompts absent specific reason to trust them, since there is no way to verify one; and for anything that will inform a medical decision, particularly for a child, use a clinician instead of this device.

B. For Vendors Building This Class of Device

Every issue in this paper has a decades-old, well-understood remedy, none requiring novel research: encrypt the media channel (DTLS or SRTP over the existing UDP transport); authenticate the device cryptographically via a per-device key or certificate provisioned at manufacture, since an

SSID is an identifier and not an authenticator; generate access-point credentials from real entropy rather than a derivation function; sign firmware and verify the signature on-device against a key burned in at manufacture, the single control that would have neutralized Section IV-D regardless of every other finding; treat device-reported state as untrusted input to security decisions; and publish a monitored security contact and a `security.txt` file. These recommendations track the baseline technical controls in NIST IR 8259A [8] and the criteria behind the U.S. Cyber Trust Mark program defined in NIST IR 8425 [9], neither of which this product meets on any axis tested. CISA's IoT acquisition guidance [10] is a useful procurement-stage checklist for buyers of this device class more broadly.

IX. EXPLOIT-CODE AND ETHICS STATEMENT

I am not publishing the BSSID-to-password derivation routine, the rogue access point implementation, or tooling to reconstruct video from a capture file. The affected behavior is described in this paper in enough technical detail for defenders, researchers, and anyone in the supply chain to understand and act on it, without shipping a working attack toolkit against an unpatchable device that has an unknown but non-trivial number of units already in homes. There is no automatic update path and no vendor security contact through which a fix could be distributed even if one existed; publishing working tooling in that position would harm current owners without meaningfully advancing anyone's understanding beyond what Section IV already provides. Researchers who require additional technical detail for defensive or coordination purposes may contact me directly at mdubbrin@gmail.com.

X. DISCUSSION: A BROADER PATTERN

Cheap white-label IoT hardware is a large and growing share of the devices in people's homes, built on reference designs copied across unrelated product lines with the security posture intact, meaning absent. The chipsets in this device appear across a wide range of consumer electronics; the design failures documented here are not specific to ear cameras, and Table V shows the same four failure classes recurring from inexpensive DVRs up through FDA-recalled implanted medical devices.

What makes this case worth publishing is the gap between the sensitivity of the data and the effort spent protecting it. The product ships an on-device neural network for image processing; someone spent real engineering time on the imaging pipeline. The video that pipeline produces goes out over the air in the clear, protected by a password printed in every beacon frame. That is not a resource constraint; it is a priorities problem, and a predictable outcome when no party

in a supply chain, whether original equipment manufacturer, brand, reseller, or app developer, is accountable for security, and no regulation currently forces the question for a device in this category.

XI. CONCLUSION

Four independently unremarkable IoT defects, chained, let anyone within radio range of a Softish C6 watch its video feed, impersonate it to its own companion app, and push it unsigned firmware, with a total interaction cost, at the worst step, of one tap. The device's threat model, to the extent one exists, rests entirely on the assumption that nobody nearby is listening to public radio broadcasts. That assumption fails for an inexpensive Wi-Fi adapter, and it fails for a device that is, by design, pointed inside a human body.

Acknowledgments. I thank CISA for coordination in the continued absence of a responsive vendor security contact.

REFERENCES

[1] CISA. Advisory pending publication.

- [2] B. Krebs, "Source Code for IoT Botnet 'Mirai' Released," Krebs on Security, 2016.
- [3] Arlo, "Arlo Wi-Fi Default Password Security Vulnerability," support advisory.
- [4] "Patch Now: TP-Link Archer NX Routers Vulnerable to Firmware Takeover," Security Affairs, 2025. CVE-2025-15517.
- [5] "Wyze Cam Flaw Lets Hackers Remotely Access Your Saved Videos," BleepingComputer. CVE-2019-9564.
- [6] CISA, "ICSA-15-125-01B: Hospira Infusion Pump Vulnerabilities."
- [7] "St. Jude Medical Recalls 465,000 Pacemakers Over Security Vulnerabilities," SecurityWeek, 2017.
- [8] NIST, "IR 8259A: IoT Device Cybersecurity Capability Core Baseline."
- [9] NIST, "IR 8425: Technical Baseline for the FCC Cyber Trust Mark."
- [10] CISA, "IoT Acquisition Guidance for Organizations."